

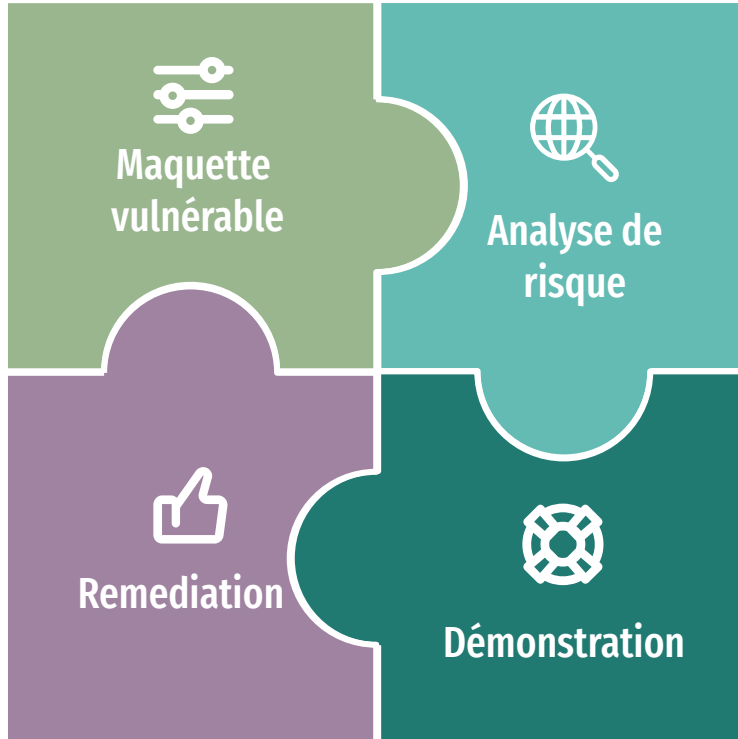
UNICAMPUS

Une université accueillante

Timote LACAMBRA
Virgile THONNIER
Jérémy GIUDICELLI
Ghislain MAUGENEST



Sommaire



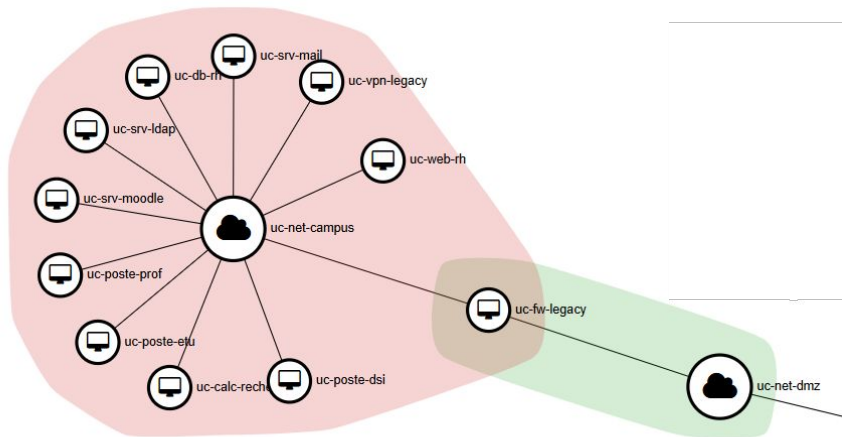
Présentation rapide de la
maquette et de ses vulnérabilité

Revue brève des 5 ateliers EBIOS RM

Mesures de remédiation mises en
œuvre à partir l'analyse EBIOS RM

Démonstration de la maquette final

Maquette vulnérable



Architecture et Sécurité Réseau

- Pare-feu obsolète
- Un seul sous-réseau
- HTTP partout

Gestion des Identités et des Accès

- Annuaire LDAP implémenté mais non utilisé -> Authentification non vérifiée
- Pas de multiplicité des services -> pas de SSO ni de MFA, fragilité des mots de passe (dont mots de passe multiples)
- Compte DSI partagé

Supervision et Opérations de Sécurité

- Aucune centralisation des logs
- Pas de SOC ni procédure incident

Vulnérabilité techniques

- Fonction de hachage obsolète
- base de donnée exposé
- mauvaise permission

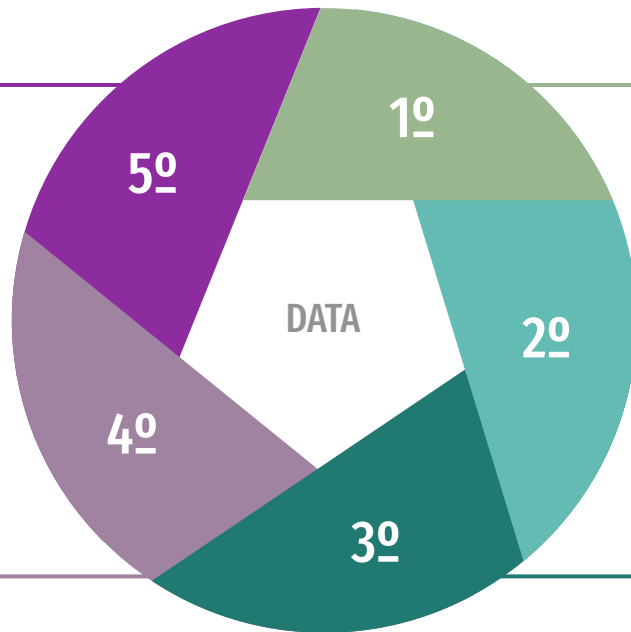
Valeurs métier

Données académiques

Relevés de notes, dossiers de scolarité, délibérations des jurys et délivrance des diplômes.

Patrimoine scientifique

Données de recherche, article, publication, thèse brevets et propriété intellectuelle



RH

Dossiers du personnel, gestion de la paie, suivi des carrières

Données personnels et contractuel

Données d'identité, dossiers d'inscription, conventions de stage

Service pédagogique

Moodle, roundcube



Événements redoutés

Altération des données

Perte de crédibilité institutionnelle et des diplômes (fraude sur les notes), litiges juridiques et erreurs financières (paie, contrats)

Intégrité

Disponibilité

Fuite/perte/destruction de données

Atteinte à la vie privée, préjudice d'image et risques légaux suite à l'exposition de données sensibles (notes, paie, contrats)

Continuité

Interruption des services

Paralysie des activités pédagogiques et administratives, avec une criticité majeure bloquant l'organisation durant les périodes d'examens

Scénarios d'attaques

1st

WIFI

Manipulation des données depuis le WiFi étudiants

2nd

Usurpation d'identité

Vol de credentials

3rd

Ransomware

- . Par phishing
- . Rebond via un mainteneur logiciel compromis
- . Exploitation d'une vulnérabilité non patchée

4th

Vol des travaux de recherche

compromission directe du serveur

rebond via un partenaire moins sécurisé

5th

Fraude au système RH

Par un ancien personnel :

compte légitime non révoqué

vulnérabilité application RH

Risque Initial vs Risque Résiduel

Vraisemblance	Certain	LOW	MODERATE	HIGH	HIGH
	Très Vraisemblable	LOW	4,5,6	1	HIGH
	Vraisemblable	LOW	LOW	MODERATE	MODERATE
	Peu Vraisemblable	LOW	LOW	LOW	LOW
		Mineur	Significatif	Grave	Critique

Impact

>

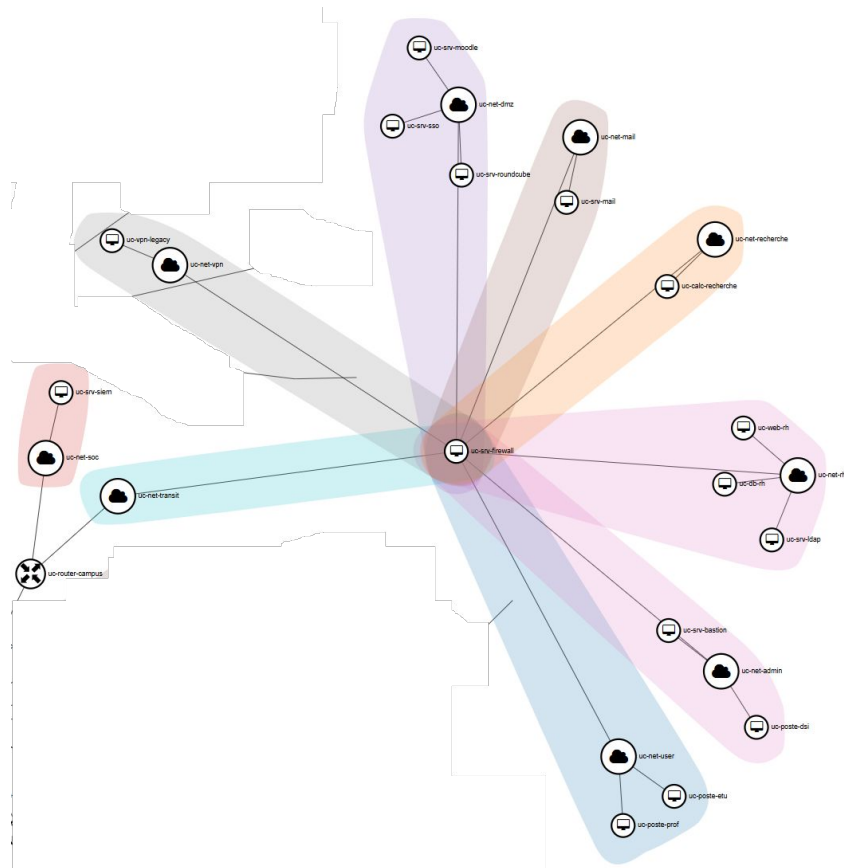
Vraisemblance	Certain	LOW	3	MODERATE	HIGH	HIGH
	Très Vraisemblable	4,5	W	1,2	MODERATE	HIGH
	Vraisemblable	6	LOW	LOW	MODERATE	MODERATE
	Peu Vraisemblable	LOW	LOW	LOW	LOW	LOW
		Mineur	Significatif	Grave	Critique	

Impact

- R01 : Compromission des résultats académiques par un étudiant
- R02 : Paralysie de l'établissement par rançongiciel
- R03 : Exfiltration et revente des données personnelles

- R04 : Exfiltration du patrimoine scientifique par un acteur étatique
- R05 : Détournement de la paie par un personnel
- R06 : Destruction de données par vengeance

Maquette V2



Architecture et Sécurité Réseau

Segmentation en 6 VLANs
Règles firewall sélectives nftables

Gestion des Identités et des Accès

SSO avec Keycloak
LDAP avec modèle ABAC
Authentification Kerberos
Interdiction de comptes partagés

Supervision et Opérations de Sécurité

SIEM, IDS, Sauvegarde immuable

Vulnérabilité techniques

Correction des mauvaises
configurations
HTTP -> HTTPS

Scénarios d'attaques

1st

WIFI

Manipulation des données depuis le WiFi étudiants

6 VLAN

2nd

Usurpation d'identité

Vol de credentials

PKI

3rd

Ransomware

- Par phishing
- Rebond via un mainteneur logiciel compromis
- Exploitation d'une vulnérabilité non patchée

BACKUP

4th

Vol des travaux de recherche

compromission directe du serveur
rebond via un partenaire moins sécurisé

Vulnérabilité techniques

5th

Fraude au système RH

Par un ancien personnel :
compte légitime non révoqué
vulnérabilité application RH

IAM



Merci

Solutions implémentées / Maquette V2

Segmentation en 6 VLANs

Règles firewall sélectives nftables

SSO avec Keycloak

LDAP avec modèle ABAC

TLS

Authentification Kerberos

Interdiction de comptes partagés

IDS

sauvegardes immuables

SIEM

Scénarios d'attaque envisagés

- 1) Manipulation des données depuis le WiFi étudiants
- 2) Vol de credentials -> usurpation d'identité
- 3) Rançongiciel par :
 - phishing du personnel
 - rebond via un mainteneur logiciel compromis
 - exploitation d'une vulnérabilité non patchée
- 4) Attaque sur la base de données personnelles :
 - vulnérabilité applicative
 - rebond via un éditeur logiciel compromis
- 5) Vol des travaux de recherche :
 - compromission directe du serveur
 - rebond via un partenaire moins sécurisé
- 6) Fraude au système RH par un ancien personnel :
 - compte légitime non révoqué
 - vulnérabilité application RH

Analyse de risque / Valeur métier

Évaluation et résultats académiques

Services pédagogiques numériques

Patrimoine scientifique

Données personnelles et contractuelles

Gestion des ressources humaines

Évènements redoutés, conséquences sur les VM

Fuite/Perte/Destruction de données :

- recherche
- personnelles
- scolarité

Altération des données :

- RH (paie, ...)

Interruption des services numériques -> influence majeure sur période d'examens

État de la maquette V1

Parefeu obsolète

Un seul sous-réseau

Aucune centralisation des logs

Pas de multiplicité des services -> pas de SSO ni de MFA, fragilité des mots de passe (dont mots de passe multiples)

Annuaire LDAP implémenté mais non utilisé -> Authentification non vérifiée

Compte dsi partagé

Fonction de hachage obsolète

Pas de SOC ni procédure incident

HTTP partout